

SIMATS ENGINEERING

CO3-ASSESSMENT TOOL 3

COURSE NAME: Ethical Hacking COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO3: Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min Total Marks: 50

Code of Conduct:

I __M Kavya 192472370__ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action

Signature of the student: Kavya

PENETRATION TESTING

1. Analyze a target network to determine whether hosts are alive without using ICMP packets.

If ICMP packets are blocked, other host-discovery techniques can be used. TCP SYN/ACK probes can identify hosts by observing responses such as SYN/ACK or RST. ARP discovery is highly effective inside a LAN because it operates at the local network layer.

Technique	Working	Suitable Environment
TCP SYN/ACK	Sends TCP probes and analyzes responses	Routed networks
ARP Discovery	Resolves IP addresses to MAC addresses	Local LAN
UDP Probe	Sends UDP packets and analyzes responses	Networks where TCP/ICMP is restricted

Therefore, TCP and ARP-based discovery can identify active hosts without relying on ICMP.

2. Compare SYN Scan and TCP Connect Scan for scanning a production server. Recommend the appropriate method.

Feature	SYN Scan	TCP Connect Scan
Handshake	Does not complete full handshake	Completes full handshake
Speed	Faster	Relatively slower
Visibility	Generally less application-level evidence	More noticeable
Resource usage	Lower	Higher
Production use	Preferred when carefully controlled	Useful when SYN scan is unavailable
Limitation	May require appropriate privileges	Creates completed connections

A **controlled SYN scan** is generally more appropriate for a production server because it is faster and avoids completing the full TCP connection. However, the packet rate should be limited to

prevent service disruption.

3. A firewall filters ports 80 and 443. Analyze alternative scanning techniques to verify service availability.

When normal probes are filtered, alternative techniques can help understand firewall behavior.

Technique	Purpose
ACK Scan	Helps determine whether ports are filtered by firewall rules
FIN Scan	Uses TCP FIN packets to analyze responses
NULL Scan	Sends packets without TCP flags to observe target behavior
Application-level check	Verifies whether the expected service is actually accessible

These techniques should be used only within the authorized assessment scope. Results should be compared with service-level checks rather than relying on a single scan.

4. Analyze scan results showing ports as Open, Closed, and Filtered.

Port State	Meaning	Security Interpretation
Open	A service is listening and accepting connections	Service should be identified and assessed
Closed	Host is reachable but no service is listening	Lower immediate risk but confirms host availability
Filtered	Probes are blocked or dropped	Firewall or ACL may be present

An **open** port represents an available service, a **closed** port indicates that no service is listening, and a **filtered** port means the scanner cannot determine the actual state because traffic is being blocked.

5. Determine the safest port scanning strategy for a hospital

network where service disruption must be avoided.

A hospital network contains critical systems, so scanning must have minimal impact.

Strategy	Reason
Slow SYN scanning	Reduces network load
Limited port range	Avoids unnecessary traffic
Low packet rate	Prevents congestion
Maintenance window	Reduces operational risk
Avoid aggressive options	Prevents service degradation

The safest approach is a **slow, controlled SYN scan with a limited packet rate**. Critical medical systems should be excluded unless specifically approved.

6. Analyze why a penetration tester chooses UDP scanning for a DNS server.

DNS commonly uses **UDP port 53** for normal DNS queries. A TCP-only scan may therefore fail to identify the UDP-based DNS service.

UDP scanning helps determine whether UDP services are exposed and whether they require further security assessment. This is important because UDP services may be overlooked during TCP-only scanning.

7. Analyze the risks of performing aggressive scans on a production environment.

Aggressive scanning generates a large amount of network traffic in a short period.

Risk	Possible Impact
IDS/IPS detection	Alerts or blocking
High traffic	Network congestion
Service overload	Slow or unavailable services

System instability	Possible crashes on sensitive systems
Legal/operational issues	Violation of assessment rules

Therefore, production environments should be scanned using controlled timing, limited scope, and prior authorization.

8. During reconnaissance, only port 22 is open. Analyze possible attack vectors.

Port 22 normally indicates an **SSH service**. The main risks include weak credentials, outdated SSH software, insecure authentication, and unrestricted remote access.

The tester should assess the SSH version, authentication configuration, access restrictions, patch status, and whether unnecessary remote access is permitted. Password attacks should only be performed when explicitly authorized.

9. Analyze how banner grabbing can assist vulnerability assessment.

Banner grabbing collects information provided by a network service.

Information	Use
Service name	Identifies the application
Software version	Helps identify outdated software
Server information	Supports technology identification
Version details	Can be compared with known CVEs

For example, if a service reveals an outdated version, the tester can compare it with trusted vulnerability databases to determine whether known vulnerabilities apply.

10. Analyze why version detection should follow port scanning.

Port scanning first identifies accessible ports. Version detection can then determine the specific

application and version running on those ports.

Port scanning → Service identification → Version detection → Vulnerability mapping

This approach reduces unnecessary scanning and allows the tester to focus vulnerability assessment on services that are actually exposed.

11. Analyze scan reports to determine which host is most vulnerable.

The most vulnerable host is generally the system with several exposed services, outdated software, weak configurations, or high-severity vulnerabilities.

Factor	Priority
Critical vulnerability	Very High
Internet-facing service	High
Outdated software	High
Unnecessary open ports	Medium–High
Low-risk service	Low

The final priority should consider **exposure, exploitability, and business impact**.

12. Analyze why Nmap timing options influence scan accuracy.

Nmap timing controls how quickly probes are sent.

Timing Approach	Effect
Faster scanning	Saves time but may cause missed responses
Moderate scanning	Balances speed and accuracy
Slower scanning	More reliable but takes longer

Aggressive timing can result in packet loss or rate limiting. Slower timing allows systems more time to respond and can improve accuracy, especially on unstable or sensitive networks.

13. Analyze firewall rules based on observed scan responses.

Firewall rules can be inferred from patterns in scan responses.

Observation	Possible Interpretation
Open	Service is reachable
Closed	Host is reachable but service is unavailable
Filtered	Firewall/ACL may be blocking probes
Inconsistent responses	Possible rate limiting or IDS/IPS

Observed results should be validated using authorized firewall configuration or security logs whenever possible.

14. Analyze the impact of IDS/IPS systems on port scanning results.

An IDS can detect scanning activity and generate alerts, while an IPS can actively block or modify suspicious traffic.

This may cause ports to appear filtered or produce inconsistent results. Therefore, scan results should be compared with IDS/IPS logs to determine whether security devices influenced the results.

15. Analyze which scan method generates the least evidence in system logs: SYN or Idle scan.

A **SYN scan** generally creates less application-level evidence than a TCP Connect scan because it does not complete the normal TCP handshake.

An **Idle scan** can potentially reduce direct attribution to the scanner, but it depends on specific network conditions and an appropriate intermediary system. Both techniques can still be detected by network monitoring systems.

PING SWEEPS

16. Analyze a network where ICMP echo requests are blocked. Determine another host discovery technique.

When ICMP echo is blocked, alternative discovery techniques can be used.

Technique	Description
TCP SYN Ping	Sends TCP SYN probes and analyzes responses
TCP ACK Ping	Uses TCP ACK responses to identify reachable hosts
ARP Scan	Discovers hosts within a local LAN
UDP Probe	Uses UDP responses for host discovery

For a local network, **ARP scanning** is usually highly effective. For routed networks, TCP-based discovery can be useful.

17. Analyze why ARP scanning is more reliable than ICMP inside a LAN.

ARP is essential for local Ethernet communication because devices use it to associate IP addresses with MAC addresses. ICMP can easily be disabled by host firewalls, while ARP is normally required for local network communication.

Therefore, ARP scanning can often discover active hosts even when ICMP echo requests are blocked.

18. Analyze ping sweep results showing intermittent responses.

Intermittent responses may occur because of:

- Network congestion
- Packet loss
- High host CPU load
- Wireless instability
- Firewall rate limiting
- Temporary service overload

Repeating the discovery with controlled timing can determine whether the problem is temporary or consistent.

19. Analyze why some active hosts do not respond during ping sweeps.

An active host may fail to respond because ICMP is disabled, a host firewall blocks the request, or network ACLs restrict the traffic.

Cause	Result
ICMP disabled	No ping response
Host firewall	Packets blocked
Network ACL	Traffic restricted
Security configuration	Host may remain hidden

Therefore, **no ping response does not necessarily mean the host is offline.**

20. Analyze how TTL values help identify operating systems.

TTL values can provide clues about the operating system because different operating systems commonly use different default TTL values.

Common Default TTL	Possible OS Family
64	Linux/Unix-like systems
128	Windows systems

255	Some network devices/Unix systems
-----	-----------------------------------

However, TTL identification is only approximate because TTL can change as packets cross routers and can also be modified.

21. Analyze the advantages of subnet-based ping sweeps over individual host testing.

Subnet-Based Sweep	Individual Host Testing
Tests many addresses systematically	Tests one host at a time
Faster	Slower
Easy to automate	More manual effort
Provides broader network visibility	Limited visibility
Useful for asset discovery	Useful for targeted verification

Subnet-based sweeps are therefore more efficient during authorized network reconnaissance.

22. Analyze how packet size affects ping sweep results.

Large packets may be fragmented or dropped because of MTU restrictions, firewall policies, or network-device limitations.

Packet Size	Possible Effect
Normal size	Usually reliable
Large size	May be fragmented
Excessively large	May be dropped

Using appropriate packet sizes and comparing results can help determine whether packet size is causing false negatives.

23. Analyze why fragmented ICMP packets may bypass

security devices.

Some older or improperly configured security devices may not inspect fragmented packets consistently. This can cause fragments to be handled differently from normal packets.

Modern firewalls generally provide better fragment handling. Therefore, fragment-related testing should be performed only in an authorized environment and should focus on identifying configuration weaknesses.

24. Analyze methods to reduce detection while performing ping sweeps.

During an authorized assessment, scan traffic can be controlled by:

- Using slower timing
- Increasing intervals between probes
- Limiting the number of hosts scanned at once
- Using appropriate TCP-based discovery when ICMP is blocked
- Coordinating testing with the security team

The objective should be to minimize operational impact while remaining within the agreed assessment scope.

25. Analyze how network segmentation affects host discovery.

Network segmentation divides systems into separate logical or physical network areas.

Segmentation Mechanism	Effect on Discovery
VLANs	Separate broadcast domains
ACLs	Restrict traffic between networks
Firewalls	Filter discovery probes
Routing boundaries	Limit direct visibility

Therefore, a host visible from one network segment may not be visible from another. Host discovery results depend on the tester's authorized network location.

SHELL SCRIPTING

26. Analyze a shell script that scans all hosts but runs slowly. Suggest improvements.

The script can be improved by removing unnecessary commands, reducing repeated operations, and using controlled parallel execution.

Problem	Improvement
Sequential scanning	Controlled parallel execution
Long timeouts	Appropriate timeouts
Repeated commands	Reuse results
Excessive output	Store only required information

These improvements can significantly reduce execution time while maintaining accuracy.

27. Analyze a shell script that reports false positives during port scanning.

False positives may occur because of packet loss, temporary network conditions, or incomplete responses.

The script should verify suspicious results using retries or a second scanning method. Multiple confirmations increase reliability and reduce incorrect reporting.

Detection → Verification → Confirmation → Final Result

28. Analyze how shell scripting automates reconnaissance.

Shell scripts can automate repetitive tasks such as host discovery, port scanning, DNS lookups, banner collection, and result logging.

Task	Possible Tool
Port scanning	Nmap
DNS lookup	Dig
Network information	Whois
Banner checking	Netcat
Logging	Bash

Automation saves time and provides consistent results across multiple authorized targets.

29. Analyze a script that stores plaintext passwords. Identify the security issue.

Plaintext password storage is a serious security weakness because anyone who gains access to the script may obtain the credentials.

Passwords should be protected using secure credential-management methods, environment-based secrets, or other appropriate authentication mechanisms. Credentials should never be unnecessarily embedded directly in scripts.

30. Analyze how logging improves penetration testing automation.

Logging Benefit	Importance
-----------------	------------

Records scan results	Easier analysis
Stores timestamps	Tracks activity
Records errors	Helps troubleshoot failures
Provides audit trail	Supports accountability
Supports reporting	Simplifies final documentation

Therefore, logging makes automated penetration-testing workflows easier to monitor, reproduce, and report.

31. Analyze why error handling is essential in security scripts.

Security scripts can encounter timeouts, unavailable hosts, permission errors, or unexpected tool output.

Without error handling, the script may stop or produce inaccurate results. Proper error handling allows the script to continue safely and clearly identify incomplete or failed operations.

32. Analyze how shell scripts integrate multiple penetration testing tools.

Shell scripts can combine multiple tools into a single automated workflow.

Example workflow:

Host Discovery → Nmap Scan → Banner Collection → DNS Lookup → Result Logging

Tools such as **Nmap**, **Netcat**, **Whois**, and **Dig** can be executed systematically. This reduces manual work and improves consistency during authorized reconnaissance.

33. Analyze the security risks of executing downloaded shell scripts.

Downloaded scripts may contain malicious commands, credential theft, backdoors, or destructive operations.

Risk	Impact
Malware	System compromise
Backdoor	Unauthorized access
Credential theft	Account compromise
Privilege escalation	Higher system access
Destructive commands	Data or service loss

Scripts should be obtained from trusted sources, reviewed before execution, and run with minimum required privileges.

34. Analyze why scripts should validate user input before execution.

Unvalidated input may allow command injection or unintended command execution.

For example, if user-controlled input is directly inserted into a shell command, an attacker could potentially alter the command's behavior. Input validation and safe argument handling help prevent this problem.

35. Analyze how scheduling automated scans benefits security monitoring.

Scheduled scans provide continuous visibility into changes in the network.

Benefit	Result
Regular scanning	Continuous assessment
Detect new ports	Identifies exposure
Detect service changes	Finds configuration changes
Compare historical results	Identifies trends
Early detection	Faster remediation

Tools such as **Cron** can schedule authorized security scans at regular intervals.

ENUMERATION

36. Analyze the information obtained from Windows enumeration that assists penetration testing.

Windows enumeration can reveal several important network details.

Information	Security Importance
User accounts	Identifies account exposure
Groups	Shows privilege relationships
Shared folders	Identifies exposed resources
Services	Reveals running applications
Domain information	Shows network structure
Security policies	Reveals configuration weaknesses

This information helps identify unnecessary exposure, excessive permissions, and potentially vulnerable services.

37. Analyze Android device enumeration results to identify potential attack surfaces.

Android enumeration can provide information about applications, permissions, services, device configuration, and debugging interfaces.

Information	Potential Risk
Installed applications	Vulnerable applications
App permissions	Excessive privileges

Running services	Exposed functionality
ADB status	Unauthorized debugging access
Device configuration	Insecure settings

The results help identify applications or configurations that require further security assessment.

38. Analyze why SMB enumeration is useful in Windows environments.

SMB enumeration is useful because SMB is widely used for Windows file and resource sharing.

Information Obtained	Importance
Shared folders	Identifies accessible resources
Username	Helps assess account exposure
Domain information	Reveals network structure
Permissions	Identifies excessive access
SMB services	Helps identify configuration issues

Therefore, SMB enumeration can reveal valuable information about Windows network resources and access controls.

39. Analyze differences between Windows and Android enumeration techniques.

Aspect	Windows	Android
Main interfaces	SMB, NetBIOS, LDAP	ADB, package manager, system services
Information	Users, shares, domains, policies	Apps, permissions, services, device details
Main attack surface	Network services and shares	Applications and device services

Common focus	Accounts and network resources	App security and device configuration
--------------	--------------------------------	---------------------------------------

The techniques differ because Windows and Android use different operating-system architectures and management interfaces.

40. Analyze an enumeration report containing usernames, shared folders, and service versions. Prioritize the information for further penetration testing.

The information should be prioritized according to severity, exposure, and potential impact.

Priority	Finding	Reason
1 – Critical	Outdated/vulnerable services	May contain exploitable weaknesses
2 – High	Administrative accounts	Higher potential impact
3 – High	Writable sensitive shares	May allow unauthorized modification
4 – Medium	Exposed usernames	Useful for security assessment
5 – Low	Non-sensitive information	Lower immediate risk

Therefore, outdated services and privileged accounts should generally receive the highest attention, followed by writable or sensitive shared resources.

CONCLUSION

Port scanning identifies exposed services, ping sweeps identify active hosts, shell scripting automates repetitive security tasks, and enumeration provides detailed information about users, services, applications, and configurations. By linking the results from these techniques, a penetration tester can identify attack surfaces, prioritize vulnerabilities, and recommend appropriate security controls while minimizing operational risk.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Identification of Port Scanning Factors	25%	Clearly identifies comprehensive and relevant strengths, weaknesses, opportunities, and threats	Identifies most factors with minor gaps	Limited or partially relevant identification	Incorrect or incomplete Port Scanning factors
Analysis	25%	Provides deep, insightful analysis of each Port Scanning component with strong reasoning	Provides good analysis with some depth	Basic analysis with limited reasoning	No meaningful analysis provided
Linkage	20%	Effectively links Port Scanning elements to derive strong strategic insights and implications	Shows some linkage with moderate insights	Weak linkage; limited strategic thinking	No linkage or strategic insight
Application	20%	Applies Port Scanning analysis effectively to the given case or scenario with clear relevance	Applies analysis with minor gaps	Limited application; lacks clarity	No clear application to context

Clarity	10%	Well-structured, clear, and logically presented with proper formatting	Generally clear with minor issues	Some structure but lacks clarity	Poorly organized and difficult to understand
---------	-----	--	-----------------------------------	----------------------------------	--